



Federal Financial Institutions Examination Council

FFIEC

Supervision of Technology
Service Providers

TSP

OCTOBER 2012

IT EXAMINATION

HANDBOOK

Table of Contents

Introduction	1
Supervisory Policy	2
Examination Responsibility	2
A. Insured Financial Institution	2
B. Insured Financial Institution as TSP	2
C. Holding Company and Non-Bank Subsidiary of the Holding Company	2
D. Bank Service Company as TSP	3
E. Independent TSPs, Including Those in the Multi-Regional Data Processing Servicers Program	3
Supervisory Programs	4
MDPS Program	4
Regional TSP Program	4
Supervision of Foreign-Based TSP Program	5
Shared Application Software Review Program	5
Roles and Responsibilities	5
Agency-In-Charge	6
Central Point of Contact	6
Examiner-In-Charge of Site or Activity	6
Risk-Based Supervision	6
Risk-Based-Examination Priority Ranking	7
Uniform Rating System for Information Technology	7
Frequency of Examinations	8
Risks Associated With TSPs	8
Risk Management	9
Audit and Internal Controls	9
Report of Examination	10
ROE Distribution	10
Customer List	10

Appendix A: URSIT	A-1
-------------------	-----

Introduction

The Board of Governors of the Federal Reserve System (FRS), the Federal Deposit Insurance Corporation (FDIC), and the Office of the Comptroller of the Currency (OCC) (each individually, Agency, and collectively, Agencies) have statutory authority to supervise third-party servicers that enter into contractual arrangements with their regulated financial institutions. ^[1]

The "Supervision of Technology Service Providers" booklet (TSP Booklet), of the FFIEC ^[2] Information Technology Examination Handbook (IT Handbook), addresses this authority and rescinds the previous version dated March 2003. The TSP booklet outlines the Agencies' risk-based supervisory program and includes the examination ratings used for regulated financial institutions and their Technology Service Providers (TSP). ^[3]

A financial institution's use of a TSP to provide needed products and services does not diminish the responsibility of the institution's board of directors and management to ensure that the activities are conducted in a safe and sound manner and in compliance with applicable laws and regulations, just as if the institution were to perform the activities in-house.

While the examinations of TSPs generally focus on the underlying information technology (IT) risk, the risk assessment process also considers all business lines in which TSPs engage to ensure that all covered services are effectively included. The Agencies expect financial institutions to have a comprehensive, enterprise risk management process in place that addresses vendor management for their relationships with TSPs. The risk management process should include risk assessments and robust due diligence for the selection of TSPs, contract development, and ongoing monitoring of all TSPs' performance. ^[4]

The Agencies conduct IT-related examinations of financial institutions and their TSPs based on the guidelines contained in the IT Handbook. The handbook is composed of the following individual booklets that address governance of risks expected of financial institutions and their TSPs as well as detailed examination procedures:

- Audit
- Business Continuity Planning
- Development and Acquisition
- Electronic Banking
- Information Security
- Management
- Operations
- Outsourcing Technology Services
- Retail Payment Systems

- Supervision of Technology Service Providers
- Wholesale Payment Systems

Management of financial institutions and TSPs should be aware of the guidance described in the IT Handbook.

Supervisory Policy

Supervisory policy provides for interagency examinations of TSPs that service insured financial institutions supervised by more than one federal financial institution regulator. The policy is expected to eliminate the need for separate examinations of TSPs by more than one regulator and to result in more efficient use of examiner resources and with less burden to the supervised TSP. Notwithstanding this policy, no federal or state regulatory agency is precluded from conducting an independent examination of any TSP that is servicing an insured financial institution for which the agency is responsible.

Federal and/or state banking agencies participating on interagency TSP examinations are precluded from levying any examination-associated fees against the examined service provider.

Examination Responsibility

Examination responsibility is determined based on the class/type of servicer as well as the class/type of insured financial institution(s) being serviced.

A. Insured Financial Institution

Technology service centers operated by an insured financial institution or its subsidiary are examined by the Agency responsible for the supervision of the financial institution.

B. Insured Financial Institution as TSP

Services provided by an insured financial institution, or by its subsidiary, to one class ^[5] or more of insured financial institutions are examined by the Agency responsible for supervising the servicing institution. The primary regulatory Agency seeks input from other interested Agencies and performs an IT examination of the entity's operations as they relate to the technology services it provides. The Agency generates a report with supporting information regarding the adequacy of its institution's servicing operations and provides the report to the primary federal regulators of the serviced institution(s). Application of the Risk-Based-Examination Priority Ranking Program (RB-EPRP) to the servicing institution is left to the discretion of its regulatory Agency.

C. Holding Company and Non-Bank Subsidiary of the Holding Company

Services provided by a financial institution holding company, or by its non-bank subsidiary, to one class or more of insured financial institution are examined by the Agency responsible for supervising the servicing entity. The primary regulatory Agency seeks input from other interested Agencies and performs an IT examination of the entity's operations as they relate to the technology services it provides. The Agency generates a report with supporting information regarding the adequacy of the entity's operations and provides the report to the primary federal regulators of the serviced institution(s). Application of the RB-EPRP to the servicing entity is left to the discretion of its regulatory Agency.

D. Bank Service Company as TSP

Responsibility for the examination of bank service companies ^[6] is based first on the type/class of entity(s) holding controlling ownership ^[7] in the servicer. Specifically:

- If there is one or more controlling owner, primary examination responsibility falls to the Agency(s) supervising the controlling owner(s).
- Where there is only one controlling owner, or where one controlling owner has claim to materially greater ownership interests relative to the others, the Agency supervising that owner has the discretion to retain primary examination responsibility with regard to any interagency examination work.
- Where controlling ownership is equally distributed, the primary examination responsibilities are rotated as agreed by the interested Agencies.

In all instances, regardless of the number of controlling owners, the Agencies supervising the serviced financial institutions have an interest in participating on interagency examinations.

E. Independent TSPs, Including Those in the Multi-Regional Data Processing Servicers Program

Responsibility for the examination of independent TSPs is based on the class of insured financial institution being serviced. If more than one class of insured institution is serviced, the examination is conducted jointly, and on a rotated basis, as agreed to among the federal financial institution regulators responsible for the classes of serviced institutions.

Examination of companies in the Multi-Regional Data Processing Servicers (MDPS) program is administered by the Agencies. The Agencies determine which TSPs are subject to examination under the MDPS program. Generally, Agency-In-Charge (AIC) responsibilities for an MDPS company are rotated among the Agencies responsible for the class of serviced, insured financial institutions after two consecutive examination cycles, ^[8] with exceptions subject to the Agencies' review and approval. As indicated in section C on page 3, if an independent MDPS company, through acquisition, becomes a

financial holding company, a bank holding company, a thrift holding company, or a non-financial institution subsidiary or affiliate thereof, the Agency supervising the holding company serves as the AIC unless such Agency chooses to rotate the responsibilities.

Examinations of independent TSPs that are not part of the MDPS program are administered by the Agencies' regional/district management under the guidelines in this booklet.

Supervisory Programs

The Agencies coordinate the interagency programs for the supervision of TSPs through the FFIEC. The programs establish responsibilities and requirements for the collaborative efforts of the Agencies to ensure effective supervision while making efficient use of examiner resources and reducing burden on the TSPs.

MDPS Program

The Agencies are responsible for the administration, coordination, oversight, and implementation of the supervisory program for the largest, systemically important TSPs: the MDPS program. The program represents a cooperative arrangement among the Agencies for the achievement of shared and consistent supervisory goals and objectives.

As a general rule, a TSP is considered for the MDPS program when the TSP processes:

- mission-critical applications ^[9] for a large number of financial institutions that are regulated by more than one Agency, thereby posing a high degree of systemic risk; or
- from a number of data centers located in different geographic regions.

The companies in the MDPS program can pose a significant risk to the banking system if one or more have operational or financial problems or fail. Because these companies provide services to banks, savings associations, and credit unions, the supervisory program allows for effective use of Agencies' resources, reduced burden to the MDPS, shared knowledge of the company's operations, development of a joint supervisory strategy, and generation of a single Report of Examination (ROE) for the company and its client-regulated financial institutions.

Regional TSP Program

The Agencies' district or regional offices are responsible for the administration, coordination, oversight, and implementation of the supervision of TSPs that are local and smaller in size or complexity. Although these TSPs are not part of the MDPS program, they are supervised in a similar manner and under the guidelines of the Supervisory

Policy previously discussed.

Supervision of Foreign-Based TSP Program

Advances in technology enable financial institutions to provide customers with an array of products, services, and delivery channels. One result of these changes is that financial institutions are entering into contractual obligations with, and outsourcing banking activities to, foreign-based TSPs (FBTSP). Outsourcing or subcontracting (by domestic TSPs) to FBTSPs raises country risk, in addition to other risks presented by the use of domestic TSPs. Country risk is the exposure to social, economic, and political conditions in a foreign country that could adversely affect the ability of a FBTSP to meet its contractual obligations.

The Agencies' supervisory approach to cross-border outsourcing emphasizes the responsibility of the serviced financial institution to conduct adequate due diligence, manage risks appropriately, comply with applicable U.S. and foreign laws and regulations, and ensure access to critical information with respect to the services being provided by the FBTSP. If circumstances warrant, the Agencies arrange, through the appropriate foreign regulatory agencies, to obtain information related to the services provided to U.S. regulated financial institutions. If significant risks and concerns warrant on-site supervision of the FBTSP, the Agencies secure approval of their representatives at the Task Force on Supervision (TFOS) ^[10] before conducting the examination. For these examinations, the Agencies use the same interagency process defined in this TSP booklet and described throughout the IT Handbook.

Shared Application Software Review Program

The Agencies established the Shared Application Software Review (SASR) program to effectively employ interagency resources in uniform reviews of software packages or systems. Shared application software packages include stand-alone software and integrated (turnkey system) packages. Generally, these are purchased software that involves mission-critical, core, or high-risk applications widely used at financial institutions.

The SASR program is not limited, however, to the review of shared application packages. The Agencies also use SASRs to support interagency safety and soundness initiatives when focusing on higher-risk applications in larger financial institutions. A SASR can evaluate financial institutions' software packages for use in wire transfer, capital markets, derivatives development/record keeping, securities transfer, asset management, Bank Secrecy Act and anti-money laundering, consumer compliance, or other lines of business.

An internal, confidential SASR report is developed strictly for regulatory purposes. The report is not provided to the company that developed the software application or to the user financial institutions. The information in the SASR report is intended to augment and expedite the Agencies' supervisory process by identifying potential systemic risks and presenting information, suggestions, and instructions to aid in completing the examinations of financial institutions that use the various applications and software products covered by this program.

Roles and Responsibilities

Agency-In-Charge

Based on an annual schedule approved by either the Agencies or the Agencies' district/regional offices, the Agencies select an AIC for each examined TSP.

Central Point of Contact

Each Agency assigns a qualified IT examiner to serve as its Central Point of Contact (CPC) for each company in the MDPS program, and where appropriate, for regional TSPs. ^[11] The selected CPCs form the CPC team, which serves as the primary group for all interagency examination-related activities, including developing supervisory strategies, performing examination activities, and pursuing the resolution of any significant findings. The CPC for the AIC is designated as the Lead CPC.

For TSPs that do not have designated CPC teams, the examiners assigned by the AICs are responsible for the supervision and oversight of the TSPs. These examiners carry out their responsibilities in collaboration with examiners from participating Agencies.

Examiner-In-Charge of Site or Activity

Some examinations of sites or specific supervisory activities of a TSP may have an examiner, who is not a member of the CPC team, assigned as Examiner-In-Charge (EIC). In these situations, the EIC conducts the assignment under the direction of the CPC team and is responsible to the Lead CPC for the administration and overall performance of the supervisory activity. The EIC keeps the CPC team informed of examination progress and findings.

Risk-Based Supervision

The Agencies' IT examination process is based on the concept of ongoing, risk-based supervision. This includes the identification and selection of TSPs warranting interagency supervision and the development of a risk-based supervisory strategy for each of these entities. This approach provides for examination coverage of selected TSPs, including core application processors, electronic funds transfer switches, Internet banking providers, item processors, managed security servicers, and data storage servicers. ^[12]

The examinations of TSPs focus on the following underlying risk issues that affect the client financial institutions or the institutions' customers:

- **Management of technology.** The planning and oversight of technology resources and

services, ensuring they support the strategic goals and objectives of the TSP and its serviced financial institutions.

- **Integrity of data.** The accuracy and reliability of automated information processes and associated management information systems.
- **Confidentiality of information.** The protection of information from intentional or inadvertent disclosure to unauthorized individuals.
- **Availability of services.** The resilience of the TSP, including effective disaster recovery, business continuity plans, and adherence to service-level agreements.
- **Compliance.** TSPs are expected to provide services to client financial institutions to help them comply with applicable laws, rules, regulations, and policies.
- **Financial stability.** The maintenance of sufficient capital and liquidity to support ongoing operations and the ability to generate profit to ensure future viability. Financial difficulties at the TSP can negatively affect the safe and sound operations of serviced financial institutions through deteriorating quality of service, reliability of service, or adequacy of controls.

Risk-Based-Examination Priority Ranking

The Agencies use the Risk-Based-Examination Priority Ranking Program (RB-EBR) in determining the overall level of risk a TSP presents to its client financial institutions. The Agencies also use the RB-EPRP to prioritize and establish the frequency of TSP examinations. The RB-EPRP ranks TSPs based on the risk their business lines, controls, and risk management processes present to their client financial institutions.

Uniform Rating System for Information Technology

The Agencies use the Uniform Rating System for Information Technology (URSIT) to uniformly assess and rate IT-related risks of financial institutions and their TSPs. The primary purpose of this rating system is to evaluate the examined institution's overall risk exposure and risk management performance and determine the degree of supervisory attention necessary to ensure that weaknesses are addressed and risks are properly managed. The assigned rating determines the degree of supervisory attention necessary.

The URSIT is based on a risk evaluation of four critical components: Audit, Management, Development and Acquisition, and Support and Delivery. The ratings assigned to these